

Exercice 1

Contexte : Vous êtes un pentester au sein d'une entreprise mandaté pour évaluer la sécurité des systèmes d'information et la sensibilisation des utilisateurs face aux risques liés aux attaques d'ingénierie sociale.

Objectif : Réaliser une simulation d'attaque de type "credential harvesting" à l'encontre d'un utilisateur de la machine hôte (sous Windows), en utilisant votre machine virtuelle équipée de la distribution Parrot OS.

Travail à réaliser :

1. Mettre en place un serveur malveillant capable de cloner la page de connexion du site <http://zero.webappsecurity.com/login.html>
2. Faire en sorte que l'utilisateur Windows soit redirigé vers cette page frauduleuse via l'adresse IP de la machine attaquante (Parrot OS), par exemple par l'envoi d'un lien ou par une manipulation locale.
3. Capturer les identifiants saisis par la victime sur la page clonée, afin de démontrer la faisabilité et l'impact d'une telle attaque.

Exercice 2

Contexte : Vous êtes pentester au sein d'une entreprise et devez poursuivre vos évaluations en simulant une attaque d'ingénierie sociale plus élaborée, intégrant une résolution DNS personnalisée pour renforcer le réalisme du scénario.

Objectif : Mener une attaque de type "credential harvesting" en utilisant deux machines virtuelles interconnectées, avec une résolution DNS permettant à la victime d'accéder au site cloné via un nom de domaine plutôt qu'une adresse IP brute.

Infrastructure :

- Une machine sous **Debian** (servant de pivot ou de serveur DNS)
- Une machine sous **Parrot OS** (serveur malveillant exécutant l'attaque)

Travail à réaliser :

1. S'assurer que les deux machines virtuelles soient correctement connectées à Internet et puissent communiquer entre elles.
2. Sur la machine Debian, configurer un service DNS (par exemple avec dnsmasq ou bind9) de sorte que le nom de domaine choisi (ex: connexion-securisee.local) résolve vers l'adresse IP de la machine Parrot OS. Cette étape permet de simuler un environnement contrôlé où l'attaquant maîtrise la résolution de noms.
3. Sur la machine Parrot, utiliser le Social-Engineer Toolkit (SET) pour cloner la page de connexion du site cible : <http://demo.testfire.net/login.jsp>
4. Configurer le serveur malveillant pour qu'il réponde sur le nom de domaine défini précédemment. On suppose que l'attaquant a réussi à convaincre l'utilisateur de la machine cible (Debian) de se rendre sur le site cloné. La victime accède alors au site frauduleux non pas via l'adresse IP, mais via le nom de domaine configuré, ce qui renforce la légitimité apparente de la page et augmente les chances de capture d'identifiants.

Exercice 3 : Sous Debian, Parrot et Windows

Contexte : Vous êtes pentester au sein d'une entreprise et devez évaluer la robustesse d'un réseau interne segmenté, ainsi que la capacité de l'équipe technique à détecter et bloquer des attaques provenant d'un poste compromis.

Objectif : Mettre en place une infrastructure réseau multi-sites avec un serveur DHCP sous Debian, réaliser une attaque complète depuis Parrot OS vers une machine cible Windows, puis implémenter des règles de filtrage avec iptables sur Debian pour protéger la cible.

Partie 1 – Architecture réseau

1. Affecter deux adresses IP de classe C appartenant à des plages différentes (ex: 192.168.1.0/24 et 192.168.2.0/24) sur le serveur Debian. Cela simulera un routeur ou un serveur multifonction au cœur du réseau.
2. Configurer le service DHCP sur Debian pour attribuer automatiquement une adresse IP à la machine Parrot OS, en veillant à ce qu'elle soit dans la première plage configurée.
3. Affecter manuellement à la machine Windows une adresse IP appartenant à la seconde plage de classe C du serveur Debian (celle qui n'est pas utilisée par le DHCP).
4. Activer le routage IP sur Debian et configurer les règles nécessaires pour que les trois machines (Debian, Parrot, Windows) puissent communiquer entre elles, malgré l'appartenance à des sous-réseaux distincts.

Partie 2 – Phase d'attaque

Depuis la machine Parrot OS, mener toutes des attaques étudiées en cours afin de tenter de pénétrer sur la machine Windows.

Partie 3 – Mise en place d'une protection avec iptables

Sur le serveur Debian, concevoir un script SHELL interactif exploitant iptables pour assurer une protection dynamique du système Windows.

Le script devra proposer le menu suivant à l'utilisateur (administrateur) :

- **OPTION 1** : Bloquer la communication **entrante**
- **OPTION 2** : Bloquer la communication **transitante**
- **OPTION 3** : Bloquer la communication **sortante**
- **OPTION 4** : Autoriser la communication **entrante**
- **OPTION 5** : Autoriser la communication **transitante**
- **OPTION 6** : Autoriser la communication **sortante**
- **OPTION 7** : Bloquer spécifiquement toute communication provenant de la machine attaquante (Parrot OS)